

Threat Analysis Report (STRIDE)

Initial Topology Assessment

1 Introduction

This document presents the threat analysis based on the STRIDE model for the initial topology of the network security project. The objective is to demonstrate the network's vulnerabilities before the implementation of the firewall and the VPN tunnel, in order to technically justify the applied security measures.

2 Attack Scenarios and Mitigations

2.1 1. Spoofing (Identity Spoofing)

- **The Threat:** The Malicious machine spoofs the Remote-Employee's IP address to deceive the routers (R1/R2) and gain unauthorized access to the internal enterprise network.
- **The Mitigation:** Implement strong authentication using digital certificates (PKI/CA) to cryptographically verify peer identity.

2.2 2. Tampering (Data Modification)

- **The Threat:** Because traffic travels in plaintext over the Internet, an attacker (Malicious) can intercept packets in transit (Man-in-the-Middle attack) and maliciously modify their content before they reach the servers.
- **The Mitigation:** Implement secure communication protocols that guarantee data integrity, such as the IPsec protocol.

2.3 3. Information Disclosure

- **The Threat:** A remote employee accesses internal resources over the open public network. The attacker can eavesdrop on the network (sniffing with Wireshark) and read confidential data in transit.
- **The Mitigation:** Encrypt data in transit using the ESP encapsulation of a Site-to-Site VPN tunnel.

2.4 4. Denial of Service (DoS)

- **The Threat:** The attacker floods the application servers (Server-1 or Server-2) with excessive traffic. Resources become saturated, preventing legitimate employees (IT and HR) from accessing them.
- **The Mitigation:** Deploy a firewall to filter incoming traffic, apply rate limiting, and block illegitimate requests.

2.5 5. Repudiation (Lack of Auditability)

- **The Threat:** A user (e.g., the Remote-Employee) accesses a non-critical file on the application server and alters or deletes it, then later denies having done so. Because the initial topology lacks individualized authentication and centralized logging, administrators cannot trace the action back to the specific user.
- **The Mitigation:** Enforce individual user authentication (via VPN/Proxy) and implement secure, centralized logging (e.g., Syslog) to maintain a reliable and tamper-proof audit trail.

3 Criticality Matrix (Heat Map)

The criticality assessment cross-references the probability of the attack occurring with its potential business impact.

Probability ↓ / Impact →	Low	Medium	High
High <i>(Easy to launch)</i>		4. DoS Attack <i>(Orange)</i>	3. Info Disclosure <i>(Red)</i>
Medium <i>(Requires interception)</i>		1. Spoofing <i>(Orange)</i>	2. Tampering <i>(Red)</i>
Low <i>(Requires internal access)</i>	5. Repudiation <i>(Green)</i>		

Conclusion: The implementation of the firewall (`iptables`) and the VPN (IPsec with certificates) during this Milestone successfully reduced all these unacceptable risks (red and orange zones) to an acceptable residual risk level by effectively applying the required mitigations.